

SUPPLY CHAIN VULNERABILITY & STATIC ANALYSIS REPORT

Project: Empros | Sovereign AI SOC (Agentic Swarm)

Date: May 20, 2026

STATUS: REMEDIATED & HARDENED

I. Executive Summary & Threat Context

Current Threat Landscape (May 2026 Context): We are evaluating these findings against a highly active supply chain threat environment, specifically citing recent campaigns such as the "Mini Shai-Hulud" attack (PyPI/NPM) and the "TeamPCP" credential-harvesting campaign. Attackers are actively poisoning open-source ML pipelines to exfiltrate CI/CD secrets and execute Remote Access Trojans (RATs).

This report details the security posture of the Python dependencies powering the Project Empros Agentic Swarm and Sovereign MLOps pipelines. Every static analysis flag detected by GuardDog has been forensically evaluated and subsequently remediated via architectural controls and configuration overrides.

II. GuardDog Static Analysis: Forensic Breakdown & Remediation

The GuardDog scanner flagged numerous indicators across heavy ML frameworks. These have been evaluated as **Verified False Positives** for malicious intent, representing standard architectural patterns required for hardware acceleration and metaprogramming. They have been whitelisted in the remediation phase.

1. api-obfuscation (getattr / Reflection)

Packages: torch, transformers, peft, duckdb, pydantic, datasets, pytest, sentence-transformers, trl

Context: ML frameworks use getattr for dynamic backend dispatching (e.g., routing tensor math to CPU, CUDA, or MPS) and metaprogramming.

Verdict: Verified False Positive (Whitelisted)

2. dll-hijacking & bundled_binary

Packages: bitsandbytes, pandas, torch, vllm, transformers

Context: Machine learning requires bridging to C++ and CUDA. bitsandbytes and vllm use ctypes.CDLL to load custom GPU kernels (e.g., NCCL, FlashAttention).

Verdict: **Verified False Positive (Whitelisted). Mitigated by ReadOnly=true container root.**

3. code-execution (OS Subprocesses)

Packages: pandas, pyarrow, vllm

Context: pandas uses OS binaries for clipboard APIs. pyarrow uses it for pkg-config during compilation.

Verdict: **Verified False Positive (Whitelisted). Mitigated by DropCapability=all.**

4. exfiltrate-sensitive-data

Packages: torch, transformers, vllm

Context: torch.hub and transformers fetch pretrained weights/configs from external APIs (e.g., Hugging Face Hub).

Verdict: **Functional Requirement. Mitigated by strict Egress Air-Gap and HF_HUB_OFFLINE=1.**

III. Known Vulnerabilities (CVE Analysis) & Actions Taken

- **torch==2.3.0:** Contains vulnerabilities related to deserialization of untrusted data (pickle loading).
Action Taken: Banned Python Pickle (.pt, .pth, .bin). Exclusively mandated .safetensors across the Swarm.
- **vllm==0.4.2:** No critical CVEs, essential for inputs_embeds API. **Action Taken:** Retained version, but isolated within hardened Quadlet bounds.

IV. Applied Hardening & Remediation Plan (Active)

The following architectural controls have been explicitly implemented to neutralize the attack surface without breaking the ML pipeline:

- **Version Hashing & Lockfiles:** Shifted from floating requirements to strict SHA-256 hashes using `pip-compile --generate-hashes`.
- **Egress Lockdown (Air-Gap):** Pre-downloaded all LLM weights and tokenizers to internal MinIO/S3. Forced `HF_HUB_OFFLINE=1` to block downstream network calls.
- **GuardDog Ruleset Tuning:** Applied `guarddog-config.yaml` to silence known ML heuristics, ensuring CI/CD pipelines only break on genuine anomalous injections.
- **Container Hardening:** Enforced `ReadOnly=true` and `DropCapability=all` via Podman Quadlets, neutralizing unauthorized subprocess and DLL execution.